

Security vs Usability — Scenario Comparison

Every number below is **measured** from `audit_trail` after the automated test run, not estimated. Regenerate with `node scripts/export-scenario-comparison.js`.

1) What each scenario enforces in code

Scenario	Password	Mobile OTP	Email step-up	RBAC	Activation rule
1 — Password only (baseline)	yes	no	no	no	default
2 — Password + Mobile OTP	yes	yes	no	yes	<code>scenario >= 2</code>
3 — Password + OTP + email step-up + RBAC	yes	yes	yes	yes	<code>scenario >= 2</code>

2) Measured behaviour

Scenario	Attempts	Success	Blocked/step-up	Avg risk	Avg elapsed (ms)
1	18	4	14	57.8	6.2
2	13	4	9	34.2	4.8
3	5	3	2	37	11.6

3) The trade-off

Scenario	Real protection	Usability cost	Residual weakness
1	Stolen password = full compromise	One step, instant	No device/user binding
2	Stolen password alone is useless	Two steps, must read a 30s code	OTP phishing / SIM swap
3	Layered: password + OTP + email + RBAC all required	Four gates, possible cross-device approval	MFA fatigue encourages bypass

4) How the design removes friction without removing security

- **Trusted cookie** (`as360_trust`, 1 year) — a recognized device skips the OTP on later logins.
- **Short-lived threat factors** (5 min) — consecutive failures raise risk briefly, then decay.
- **Risk bands** — a trusted user on a known network sees no extra step at all.
- **Cross-device approval** — the challenge lands on the already-trusted device.